



INFORME EJECUTIVO Y TÉCNICO DE PENTESTING

Evaluación de Seguridad Ofensiva, Hackeo Ético y
Verificación OWASP ASVS v4.0.3

OCTUBRE DE 2026

 Índice / Tabla de Contenidos

1. Resumen Ejecutivo y Ficha Técnica	Pág. 3
2. Métricas de Hallazgos	Pág. 4
1. Gráficos de Distribución (Calculadora (CVSS), OWASAP (ASVS))	Pág. 5
3. Detalle de Vulnerabilidades e Incidencias Registradas	Pág. 6
2. Listado Resumido y Detalle de Hallazgos (1 tickets)	Pág. 7
4. Conclusiones y Plan de Remediación Recomendado	Pág. 9

1. Resumen Ejecutivo y Ficha Técnica

El presente informe consolida los resultados y hallazgos identificados durante la ejecución de las pruebas de penetración (Pentest) y evaluación de seguridad sobre la plataforma Software Seguro.

El objetivo principal de esta evaluación es identificar de forma proactiva vulnerabilidades de seguridad que pudieran ser explotadas por actores maliciosos, permitiendo a la organización implementar los controles correctivos pertinentes antes de su despliegue o puesta en producción, mediante la ejecución de los laboratorios planteados por los profesores en clases.

Parámetro / Campo Detalle de la Evaluación	
Tipo de Evaluación	Penetration Testing (Box Gris)
Estándar Principal	OWASP ASVS 4.0.3 (Level 1) & OWASP Top 10
Período de Pruebas	24/09/2026 - 01/10/2026
Entorno de Evaluación	Ambiente de Staging
Clasificación del Documento	ESTRICTAMENTE CONFIDENCIAL

2. Métricas de Hallazgos

A continuación se consolidan las métricas obtenidas sobre el estado actual de los hallazgos técnicos registrados durante la auditoría.

Distribución por Calculadora (CVSS)



Total contabilizado: 1

Distribución por OWASAP (ASVS)



CATEGORÍA	CANT.	%
V1.4.3	1	50.0%
V5.1.1	1	50.0%

Total contabilizado: 2

3. Detalle de Vulnerabilidades e Incidencias Registradas

A continuación se presenta el catálogo detallado de tickets de vulnerabilidades identificadas durante el análisis, incluyendo evidencias técnicas, impacto estimado y recomendaciones de remediación.

HALLAZGO #1

Nuevo

Software Seguro

v1.0.0

Plantilla: Laboratorios

Ref ID: LAB-001

TÍTULO / NOMBRE DEL HALLAZGO

Turnero - IDOR

URL AFECTADA

https://chl-d48df94b-cd83-47ca-b21b-1d2446e69073-turnero.softwareseguro.com.ar

ENDPOINTS

GET /api/1/appointments/

DESCRIPCIÓN

Enunciado

Al acceder al sistema, verás tus próximos turnos médicos. Tu compañero Fer también necesita un turno, pero el usuario "xdalvik" ha reservado demasiados turnos de manera intencionada para incomodar a los demás.

¿Podrías eliminar todos los turnos de "xdalvik" sin afectar los turnos del resto de los usuarios?

Usuario: luis

Clave: Luis.4321

PASO A PASO

- 1- Primero antes de realizar el login, abrir el DevTools
- 2- Consulto la petición GET /api/1/appointments/ para obtener el ID del usuario "xdalvik"
- 3- Se realiza prueba y modificación del ID en GET /api/1/appointments/ hasta encontrar al usuario en /api/101/appointments/
- Una vez identificados los turnos
- 4- Ejecutar la petición DELETE:
- /api/appointments/10

- /api/appointments/11

- /api/appointments/12

- /api/appointments/13

No hay evidencias seleccionadas

4. Conclusiones y Plan de Remediación Recomendado

Se recomienda al equipo de desarrollo y DevOps priorizar la solución de los hallazgos de severidad Crítica y Alta antes del pas o a producción.

Una vez completadas las correcciones por parte del equipo técnico, se sugiere programar una re-evaluación (Re-Test) para verificar formalmente la efectiva mitigación de las vulnerabilidades reportadas.

Informe Elaborado por:

Benjamin Fagiano

